Introduction à la cybersécurité

Corrigé d'examen

Source : examen-2025-09-03.pdf · 20 questions

En-tête : 3 septembre 2025, seconde session, série A.

Question 1 · B, C, E Un ensemble de machines compromises peut envoyer massivement des requêtes normales. La saturation prive alors les usagers légitimes du service, même sans vol de mot de passe ni blocage IP suffisant.

Ch. 1, disponibilité et attaque DDoS, PDF p. 33–34

Question 2 · A, C, D La sécurité doit tenir lorsque l'adversaire connaît le système : seul le secret de la clé est indispensable. L'usage doit rester simple et la clé doit pouvoir être remplacée après une compromission.

Ch. 1, principes de Kerckhoffs, PDF p. 67–69

Question 3 · A, C, D Le chiffrement est inversé avec la clé appropriée et protège le contenu. Le hachage résistant à la préimage n'a pas de mécanisme de déchiffrement et permet un contrôle d'intégrité si l'empreinte de référence est fiable.

Ch. 2, hachage et chiffrement, PDF p. 76–77 et 93–94

Question 4 · B Une signature vérifiable rattache une action à la clé du signataire. Authentifier une session ou enregistrer des journaux sans autre garantie ne suffit pas à empêcher la contestation de l'action.

Ch. 1, non-répudiation, PDF p. 57–58

Question 5 · A, B, E Le critère strict exige qu'après le changement d'un bit d'entrée, chaque bit de sortie change avec une probabilité de 1/2. Cette sensibilité brouille les corrélations utiles à la cryptanalyse, notamment les indices qu'exploiterait une recherche par petites modifications.

À noter : F est défendable pour une attaque qui exploite précisément la corrélation entre petites modifications d'entrée et de sortie. Il ne s'agit pas d'une garantie générale.

Ch. 2, effet d'avalanche et indépendance, PDF p. 90–91

Question 6 · A, C, D Une seule clé secrète sert dans les deux sens. Le chiffrement est rapide sur les données, mais les parties doivent établir ou transmettre cette clé de façon sûre.

Ch. 2, chiffrements symétriques, PDF p. 119–124

Question 7 · A, B, C, D Les décalages possibles sont peu nombreux, les fréquences de lettres restent reconnaissables, une même clé donne un résultat déterministe et changer une lettre n'en modifie qu'une en sortie.

Ch. 2, faiblesses du chiffre de César, PDF p. 113–116

Question 8 · A, C Le texte est découpé en blocs de longueur fixe. Beaucoup de modes initialisent le traitement avec un IV ; en CBC, la dépendance entre blocs vient du mode de chaînage et non du remplissage.

Ch. 2, chiffrement par blocs et CBC, PDF p. 125–126

Question 9 · F Le signataire utilise sa clé privée et la vérification utilise la clé publique. Le mécanisme ne masque pas le message ; observer la clé publique et des signatures valides ne doit pas permettre de signer un nouveau message.

Ch. 2, signatures numériques, PDF p. 146–149

Question 10 · B, D, E Une autorité certifie le lien entre une clé publique et son propriétaire. La PKI organise le cycle de vie des certificats et rend plus sûre l'utilisation des clés dans les services réseau.

Ch. 3, certificats et PKI, PDF p. 181–185 et 196

Question 11 · A, B, C, D, E Le certificat contient la clé publique et son algorithme, les identités du sujet et de l'émetteur, un numéro de série, les dates et la signature de l'émetteur. Il ne transporte pas la clé privée du sujet.

À noter : Le numéro de série est unique par émetteur. La réponse E vise le cas usuel d'un certificat signé par une CA, pas tous les usages possibles du format X.509.

Ch. 3, certificat X.509 v3, PDF p. 181, 185 et 197

Question 12 · B, D Le serveur conserve une empreinte calculée par une fonction lente adaptée aux mots de passe, avec un sel propre à chaque compte. Un hachage fixe produit côté client et réutilisé tel quel pourrait devenir un secret rejouable.

Ch. 4, stockage, sel et fonctions dédiées aux mots de passe, PDF p. 238–245

Question 13 · A, C, E Des catégories de facteurs différentes rendent moins probable que l'attaquant puisse toutes les présenter. Cette défense réduit notamment l'efficacité du phishing qui dérobe le seul mot de passe, sans rendre toutes ses formes inoffensives.

Ch. 4, facteurs et MFA face à l'ingénierie sociale, PDF p. 218 et 220–221

Question 14 · A, C, D Un OTP déjà consommé ne doit pas être accepté une seconde fois. Les valeurs peuvent être dérivées de l'heure partagée ; Lamport utilise à la place une chaîne de hachages consommée à rebours.

À noter : La protection concerne le rejeu après utilisation. Elle n'empêche pas un attaquant d'essayer de relayer un code encore valide.

Ch. 4, mots de passe à usage unique et schéma de Lamport, PDF p. 295–296

Question 15 · B, C, D Le serveur peut refuser un nonce déjà vu, une requête trop ancienne ou un jeton déjà consommé. Un horodatage seul laisse subsister un rejeu à l'intérieur de la fenêtre de validité.

Ch. 2, rejeu, PDF p. 132–133 ; ch. 4, challenge-réponse et code à usage unique, PDF p. 249, 295 et 369

Question 16 · A, C OAuth accorde un accès délégué sans donner les identifiants à l'application. OpenID fédère l'identité ; dans le scénario du cours, le fournisseur de confiance authentifie l'utilisateur et le serveur de l'application échange le code contre le jeton.

À noter : E est défendable pour le parcours illustré, dans lequel le fournisseur authentifie l'utilisateur. OAuth seul délègue l'autorisation et ne fournit pas une preuve d'identité à l'application.

Ch. 1, transparence et délégation, PDF p. 71 ; ch. 4, OAuth, PDF p. 356–358 et 369

Question 17 · A, B, C, D On limite les droits à ceux dont une tâche a besoin, y compris pour les administrateurs. On répartit les responsabilités et on décrit les règles de façon à pouvoir détecter automatiquement les incohérences.

Ch. 4, contrôle d'accès, PDF p. 309–312

Question 18 · A, B, D, F Dans le scénario TLS du cours, le chiffrement protège la confidentialité, l'authentification cryptographique des données protège l'intégrité, la fraîcheur et le séquencement aident contre le rejeu et le certificat permet d'authentifier le serveur.

À noter : Le TLS moderne intègre l'intégrité au chiffrement authentifié (AEAD) plutôt que d'ajouter systématiquement un HMAC séparé. L'anti-rejeu ne couvre pas intrinsèquement les données 0-RTT de TLS 1.3 (RFC 8446, § 8).

Ch. 2, chiffrement authentifié, PDF p. 132–136 ; ch. 5, TLS, PDF p. 379 et 383–387

Question 19 · B, D Une zone intermédiaire sépare les services exposés des segments internes et filtre les passages. Elle réduit ainsi les possibilités de propagation après une compromission.

Ch. 5, topologie réseau et DMZ, PDF p. 426 et 441–449

Question 20 · A, D, E, F 802.1X contrôle l'ouverture d'un port filaire ou sans fil après authentification. EAPOL transporte les échanges entre le terminal et l'équipement d'accès, qui relaie habituellement la demande vers un serveur RADIUS.

Ch. 5, authentification réseau et 802.1X, PDF p. 462–467